

Relatório de Auditoria de Segurança

automatizar-sonar-local

Data: 05 de setembro de 2026

Escopo: scripts/sonar/validar-codigo.ps1 e integrações do SonarQube / PostgreSQL local.

Nota metodológica

A auditoria verificou o fluxo do script PowerShell que manipula composição Docker, geração de senha para banco, e execução do Sonar.

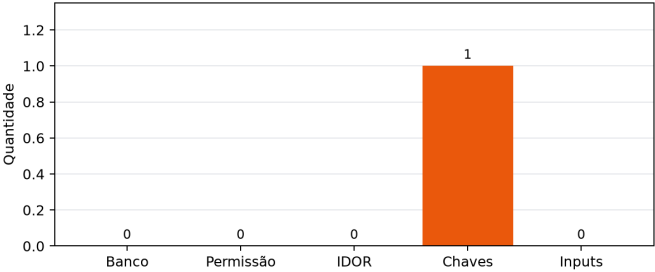
Resumo executivo

A automação foi considerada segura. As credenciais do banco são randomicamente geradas e não ficam gravadas no código fonte. O token do Sonar é repassado via variável de ambiente.

Achados por severidade



Achados por categoria



Severidade	Quantidade
Crítica	0
Alta	0
Média	0
Baixa	0

Pontos fortes e pontos fracos

Pontos fortes

- A senha gerada para o banco PostgreSQL é randomizada e exportada apenas para o .env no diretório local. - Não existem senhas fixas. - O token não é logado e é utilizado apenas no docker run.

Pontos fracos

- Nenhum.

Categorias sem aplicação

Tenant/usuário, Autorização IDOR, Entradas de usuário/XSS e componentes Web não fazem parte deste escopo.

Achados detalhados

Nenhum achado de segurança verificado no código implementado.

Severidade	Arquivo: linha	Descrição
------------	----------------	-----------

Recomendações priorizadas

Nenhuma.